REFERENCE · OWASP MAPPING

Threats T1–T8 Mapped to the OWASP Top 10 (Agentic 2026 · LLM 2025 · Classical)

Each threat in Figure 2 is a well-documented attack class. Mapping them to the OWASP lists lets the rest of the series refer to T1…T8 and cite the standard identifiers rather than re-describing each attack.

Two OWASP lists are relevant. The **OWASP Top 10 for LLM Applications (2025)** describes failure modes of any application that embeds a language model: prompt injection, sensitive information disclosure, improper output handling, and so on. The **OWASP Top 10 for Agentic Applications (2026)** extends this to systems in which the model is given tools, memory, and autonomy; its entries describe what happens when a fooled model can *act*. Because our agent reads and writes a database, several of the threats are also classical web and API weaknesses in new clothing—broken object-level authorization and SQL injection in particular—so the classical identifiers are listed as well.

QUESTION	THREAT	WHAT THE ATTACKER DOES	OWASP AGENTIC 2026	OWASP LLM 2025	CLASSICAL
Q2	T1 Prompt injection → model-written SQL	Types instructions that override the system prompt; the model composes and runs arbitrary SQL through `execute_sql`.	ASI01 Goal Hijack ASI02 Tool Misuse ASI05 Code Execution	LLM01 Prompt Injection LLM05 Improper Output Handling	A03:2021 Injection
Q4	T2 Poisoned rows & raw PII into the model	Writes instructions into a free-text column the agent will later read; or over-broad queries return SSNs and card numbers into the model's context and logs.	ASI01 Goal Hijack ASI06 Memory & Context Poisoning	LLM01 Prompt Injection LLM02 Sensitive Info Disclosure LLM04 Data Poisoning	—
Q1 Q3	T3 Shared admin account (confused deputy)	Does nothing special: the agent already connects as one privileged account, so any mistake or injection exposes every tenant's rows and columns.	ASI03 Identity & Privilege Abuse	LLM02 Sensitive Info Disclosure LLM06 Excessive Agency	API1:2023 BOLA / IDOR
Q1	T4 Identity spoofed in tool arguments	Convinces the model to pass `user_id="bob@example.com"` to a tool whose schema lets the model choose the caller.	ASI02 Tool Misuse ASI03 Identity & Privilege Abuse	LLM06 Excessive Agency	API1:2023 BOLA / IDOR

QUESTION	THREAT	WHAT THE ATTACKER DOES	OWASP AGENTIC 2026	OWASP LLM 2025	CLASSICAL
Q1 *(appears in Part 04)*	T5 Token passthrough across hops	Once a tool server exists, the agent forwards the user's broad frontend token to it; a compromised server replays that token against every other API it was valid for.	ASI03 Identity & Privilege Abuse ASI07 Insecure Inter-Agent Communication	—	OAuth 2.1 / MCP Authorization Spec
Q7	T6 Network exposure & exfiltration	Reaches the database from outside (public IP, flat VPC), or makes the agent send retrieved rows to an external endpoint, including via a rendered Markdown image link.	ASI05 Code Execution ASI10 Rogue Agents	LLM02 Sensitive Info Disclosure	—
Q5	T7 Unapproved / duplicated writes	Triggers a refund or cancellation with no human confirmation; a timeout retry runs the same mutation twice.	ASI02 Tool Misuse ASI08 Cascading Failures	LLM06 Excessive Agency	—
Q7	T8 Repudiation — no end-to-end trace	After an incident, the database log shows only the shared account; nothing links the query to a user, a session, or a prompt.	ASI09 Human-Agent Trust Exploitation	—	Logging & Monitoring Failures
Q6	T13 Bulk extraction & cost flooding (extended catalog)	Pages through every row "1,000 at a time", or triggers warehouse-wide scans on each turn.	ASI02 Tool Misuse	LLM02 Sensitive Info Disclosure LLM10 Unbounded Consumption	—

Two observations follow from the table. First, several threats share an OWASP category (`ASI03` appears four times) because the root cause—one privileged identity standing in for every user—shows up at more than one point in the architecture. Second, no threat is closed by instructing the model. Every row needs a control that sits *outside* the model: in the identity layer, in the tool server, in the database engine, or in the network. The next parts add those controls one component at a time.